

# Phase 1, Context Analysis and Framing

**Product:** NexaPay, internal fintech operations dashboard **Author:** Samuel, QA Automation Senior (technical assessment) **Date:** 15 August 2026 · **Version:** 1.0 **Environment under test:** http://149.56.128.57:3200 (demo)

---

## 1. Product synthesis, in my own words

NexaPay is an **internal back-office console for a payments operation**. Three roles, Admin, Manager, Member, sign in to read a transaction ledger, watch a handful of KPIs, and *move real money out* through two separate paths: a full Transfer form and a three-step “Send Money” modal. There is also a CSV/PDF upload, an Admin user-management table, and an EN/FR runtime toggle.

The framing that matters for testing is not “dashboard”. It is this:

NexaPay is a **write-side financial system with a reporting surface bolted on**. Two of its eight documented areas can debit an account. Everything else is read-only.

That asymmetry drives every decision in the strategy. A rendering bug on the spending chart costs an operator ten seconds of confusion. A missing server-side ceiling on POST /transfers costs whatever the attacker types. The declared criticality in Annexe B.2 already says this, Authentication, Transfer form and Send Money modal are all “Critique”, and my own analysis agrees, with one amendment I set out in §7.

Three properties are non-negotiable in this domain and none of them is a feature a user can see:

| Property                   | Why it is existential here                       | Where the brief addresses it                       |
|----------------------------|--------------------------------------------------|----------------------------------------------------|
| <b>Financial integrity</b> | A wrong amount is unrecoverable once settled     | R03 (form only)                                    |
| <b>Idempotence</b>         | Retries are normal; double debits are not        | Annexe F header only — <i>no rule, no contract</i> |
| <b>Auditability</b>        | 7-year immutable retention is a legal obligation | Annexe D, untested                                 |
| <b>Access control</b>      | Roles gate who can move money and see whose data | R06, R10                                           |

The product is described as pre-industrialisation with public exposure planned next quarter. My read after exploring the environment is that the **functional surface is further along than the control surface**, the screens work, the guarantees underneath them largely do not exist yet.

---

## 2. Critical business journeys

Ranked by *expected loss*, not by feature size. I keep the business’s own criticality where I agree with it and flag the two places I do not.

| #         | Journey                                             | Business criticality | My assessment               | Justification                                                                                                                                                                                                                                                                                    |
|-----------|-----------------------------------------------------|----------------------|-----------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>J1</b> | <b>Execute a transfer</b> (form + Send Money modal) | Critique             | <b>Critique — confirmed</b> | The only irreversible action in the product. Failure modes are unbounded loss (no ceiling), duplicate loss (no idempotency), or wrong-recipient loss. Annexe G extract B shows a real double debit.                                                                                              |
| <b>J2</b> | <b>Authenticate &amp; hold a session by role</b>    | Critique             | <b>Critique — confirmed</b> | The gate in front of J1 and J4. If role is not enforced server-side, every other control is decoration.                                                                                                                                                                                          |
| <b>J3</b> | <b>Read the ledger &amp; KPIs</b>                   | Moyenne              | <b>Élevée — raised</b>      | Operators authorise J1 <i>based on what J3 shows them</i> . A balance that overstates available funds directly causes a bad transfer. Annexe F.6 already documents a \$3,491 unexplained gap between the table total and the Balance KPI. A read defect here is a write defect one step removed. |

| #  | Journey                              | Business criticality | My assessment            | Justification                                                                                                                                                                                                                                                    |
|----|--------------------------------------|----------------------|--------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| J4 | <b>Administer users</b> (Admin only) | Élevée               | <b>Critique — raised</b> | The endpoint backing it returns every user's name, e-mail and role. Confirmed reachable with <b>no credentials at all</b> (§6). This is a personal-data breach, not a permissions inconvenience.                                                                 |
| J5 | <b>Bank settlement webhook</b>       | <i>Not listed</i>    | <b>Élevée — added</b>    | Annexes F.4, G-C and I describe an inbound webhook with signature verification, replay handling and 89 recorded verification failures. It is entirely absent from Annexe B.2's scope table. It is the boundary where an external party asserts that money moved. |
| J6 | Upload CSV/PDF                       | Moyenne              | Moyenne — confirmed      | Untrusted file ingestion is a genuine attack surface, but nothing in the docs suggests uploads feed the ledger.                                                                                                                                                  |
| J7 | EN/FR toggle                         | Faible               | Faible — confirmed       | Contained. Cosmetic. Verified opportunistically, not automated.                                                                                                                                                                                                  |

Those two amendments are the substance of this section. J3 is under-rated because it is classified as “consultation” when it is really *decision support for an irreversible action*. J5 is missing entirely, which is how a whole trust boundary ends up with no owner.

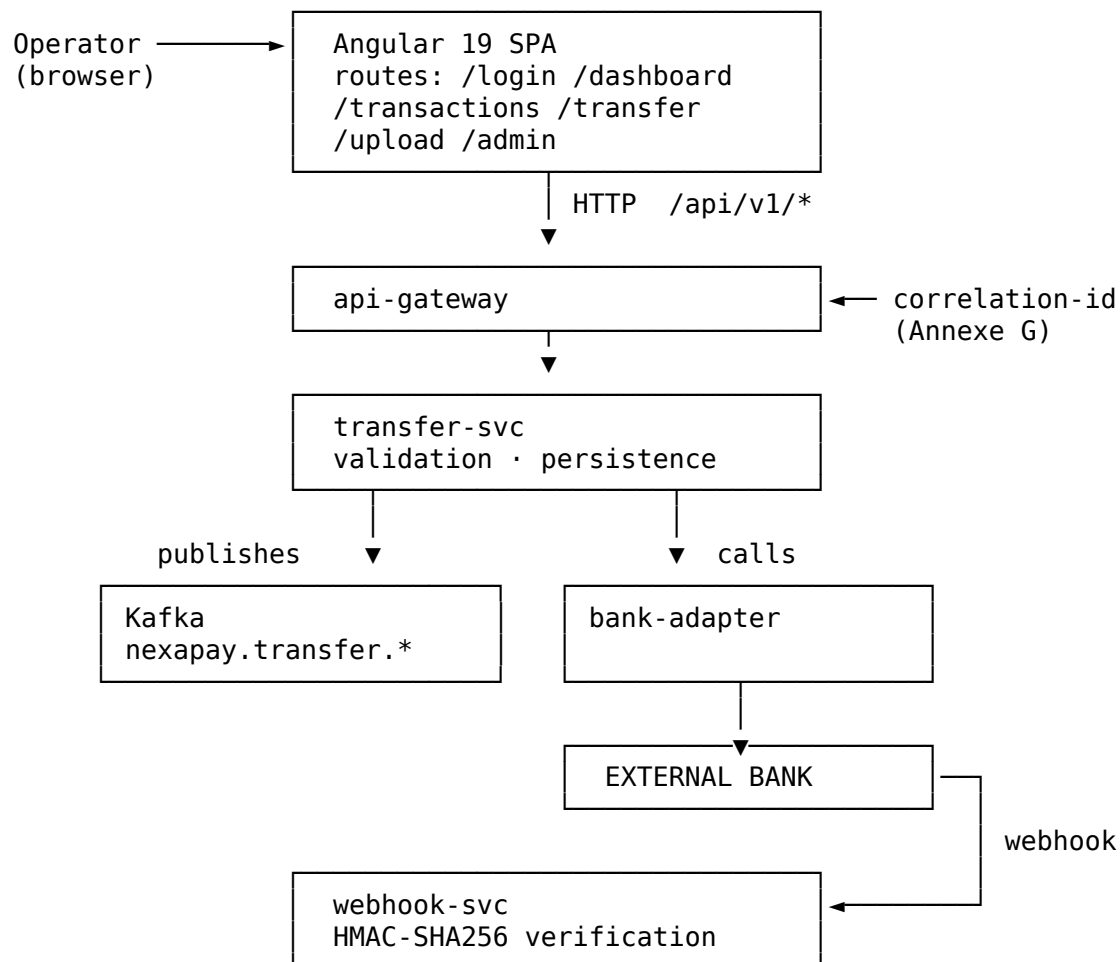
### 3. Actors, systems and dependencies

#### 3.1 Human actors

| Actor                            | Documented rights (Annexe B.3)                  | Observed reality                                                                          |
|----------------------------------|-------------------------------------------------|-------------------------------------------------------------------------------------------|
| <b>Admin</b> (u1 Amara Kofi)     | Full access, user management, global export     | Owns contacts c2, c3                                                                      |
| <b>Manager</b> (u2 Fatou Diallo) | Team view, transfers, no administration         | <b>Owns zero contacts</b> — cannot complete a contact-based transfer with the seeded data |
| <b>Member</b> (u3 Kwame Mensah)  | Individual view, transfers to own contacts only | Owns contact c1                                                                           |
| <i>Unauthenticated caller</i>    | <i>Not modelled anywhere</i>                    | <b>Can read /users, /contacts, /transactions in full</b>                                  |

That last row is the finding. The documentation models three actors; the system behaves as though there is a fourth, and it is the most powerful one.

#### 3.2 Systems and boundaries



Observability: Prometheus (Annexe I) – no Grafana, no distributed tracing, no /health, /ready or /metrics exposed (verified, §6).

### 3.3 Dependency risk register

| Dependency    | Control        | Consequence if it misbehaves                    | Testable today?                        |
|---------------|----------------|-------------------------------------------------|----------------------------------------|
| External bank | <b>None</b>    | Settlement confirmed for money that never moved | ☐ no sandbox, no stub                  |
| bank-adapter  | None           | Same, one layer in                              | ☐                                      |
| Kafka         | None           | Downstream ledgers silently diverge             | ☐ no consumer access                   |
| webhook-svc   | Signature only | Forged settlement, or replay                    | △ partially — needs the signing secret |
| Prometheus    | Read-only      | Blind operations                                | △ Annexe I extract only                |

**Five of the six systems that make a transfer real are untestable from where I stand.** That is the single most important sentence in this analysis, and it is what caps the confidence of any Go recommendation I can honestly give.

## 4. Five questions for the Product Owner

One grouped salvo, per Annexe K. Each is actionable, tied to a decision I cannot make alone, and each one changes what I build.

**Q1, Is Idempotency-Key mandatory on POST /transfers, and is the deduplication window server-side?** Annexe F shows the header on both sample requests. Annexe E's contract does not mention it. Annexe G extract B shows two keyless POSTs from user u3, 121 ms apart, both settled by the bank adapter. **Why it changes my strategy:** if the header is mandatory, TS-03c becomes a P1 regression test and a CI quality gate. If deduplication is instead meant to be server-side on a payload hash, I test a completely different property, and the fix for the double debit is in a different team's backlog. Right now I cannot tell whether Annexe G is a client bug or a missing server control.

**Q2, How is the "Total Balance" KPI derived: all transactions, or settled only?** Annexe F.6 records a table total of \$44,800 against a Balance KPI of \$48,291, a \$3,491 gap with no stated derivation. On the live environment neither figure is reproducible from the served data (I compute **-\$389.66** across all 15 records and **\$1,883.14** across completed ones). **Why it changes my strategy:** if pending and failed movements are included, an operator authorises payments against money that has not settled, and this becomes a P1 financial-integrity defect. If completed-only is correct, it is a P2 display defect. The severity swings by two levels on the answer, and TS-08b cannot assert anything until it is settled.

**Q3, Is amount cents-as-integer (per Annexe E) or dollars-as-decimal (per the live API)?** The contract declares type: integer, minimum: 1, "Montant en cents". The deployed /transactions returns signed doubles in major units, -127.85, 89.99. **Why it changes my strategy:** this decides whether my boundary values for R03 are 999999 or 9999.99, and whether every reconciliation assertion runs in integer cents or tolerates float epsilon. It also decides whether the defect I raise is against the contract or against the implementation. I have assumed cents (H-02) and written all arithmetic in integer cents; a wrong assumption here invalidates six tests.

**Q4, Is the unauthenticated read access on /api/v1/users, /contacts and /transactions a demo-environment concession, or does it reflect production configuration?** All three answered 200 with complete payloads, with no Authorization header and no session cookie. **Why it changes my strategy:** if it is a demo shim, this is an environment defect, I test the real authorisation elsewhere, and it does not touch the Go/No-Go. If the gateway genuinely has no auth middleware, it is a Blocker, the recommendation is No-Go regardless of anything else, and I stop functional work to write penetration cases instead. **This is the single question with the highest leverage in the list**, and it is why I have written the recommendation conditionally.

**Q5, Which team owns the bank-settlement webhook, and can I get a signing secret plus a replayable test event?** Annexe I records **89 signature-verification failures**. Annexe G extract C shows one event verified after an initial 401 and then correctly no-op'd twice as already\_settled. **Why it changes my strategy:** with a secret and a stub endpoint I can automate the settlement path, forged signature, replayed event, out-of-order delivery, which is J5, currently at zero coverage. Without them, J5 stays a documented residual risk I can only reason about, and the confirmation-under-2s target in Annexe D is unverifiable.

## 5. Assumptions register

Every assumption I had to make to proceed, with the risk carried if it is wrong. Anything not in Annexe C that I relied on is here.

| ID          | Assumption                                                      | Basis                                          | Risk if false                                                                                             | Score         |
|-------------|-----------------------------------------------------------------|------------------------------------------------|-----------------------------------------------------------------------------------------------------------|---------------|
| <b>H-01</b> | /api/v1 on the app origin is the API the SPA uses               | Probed and confirmed                           | Low — I would be testing a decoy surface                                                                  | ☐ Low         |
| <b>H-02</b> | amount in POST /transfers is integer cents                      | serving JSON<br>Annexe E is explicit           | <b>6 boundary tests assert the wrong values;</b> R03 appears to pass while a real \$10k transfer succeeds | ☐ <b>High</b> |
| <b>H-03</b> | R03's \$9,999.99 ceiling is intended per-transaction, not daily | Annexe B.2 wording, "montant (max 9 chiffres)" | Boundary set is wrong; a daily-cumulative rule needs stateful tests I have not written                    | ☐ Medium      |
| <b>H-04</b> | A transfer with no Idempotency-Key <i>should</i> be refused     | Inference from Annexe G-B                      | TS-03c is a false positive and I have raised a defect against intended behaviour                          | ☐ Medium      |
| <b>H-05</b> | "Total Balance" = sum of <b>completed</b> transactions          | Most conservative reading                      | TS-08b asserts the wrong invariant; a real KPI defect goes unnoticed                                      | ☐ <b>High</b> |

| ID          | Assumption                                                        | Basis                                    | Risk if false                                                                       | Score         |
|-------------|-------------------------------------------------------------------|------------------------------------------|-------------------------------------------------------------------------------------|---------------|
| <b>H-06</b> | Withdrawals/outbound transfers are negative; refunds positive     | Consistent across all 15 records         | Sign-coherence test raises false positives on legitimate data                       | ☐ Low         |
| <b>H-07</b> | The seeded 15 transactions belong to one account                  | No account field anywhere in the payload | Every reconciliation total is meaningless — I would be summing across accounts      | ☐ <b>High</b> |
| <b>H-08</b> | The demo host is a shared, non-isolated environment               | No tenancy signal; single data set       | Parallel execution corrupts results; I have already serialised writes to compensate | ☐ Medium      |
| <b>H-09</b> | data-testid hooks row, resend, transfer-date exist and are stable | Annexe H uses them                       | E2E selectors break; contained to page objects by design                            | ☐ Low         |
| <b>H-10</b> | The PIN is not a shared secret across the three demo accounts     | Not stated anywhere                      | Test data collides between roles; transfer tests interfere                          | ☐ Low         |

**H-02, H-05 and H-07 are the ones to resolve first.** All three are answerable in a five-minute conversation, and all three silently invalidate assertions rather than failing loudly, which is the worst failure mode a test suite has.

## 6. Contradictions and ambiguities found

Findings from reading the brief against the deployed environment. Items marked **[verified]** were reproduced against <http://149.56.128.57:3200> on 15/08/2026.

### 6.1 Documentation contradicts the deployed system

| #           | Contradiction                                                 | Evidence                                                                                                              |
|-------------|---------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------|
| <b>C-01</b> | <b>Contract says cents-integer, API returns dollars-float</b> | Annexe E amount: {type: integer, minimum: 1} vs GET /api/v1/transactions → -127.85, 89.99, -2500<br><b>[verified]</b> |

| #    | Contradiction                                                         | Evidence                                                                                                                                                            |
|------|-----------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| C-02 | <b>id typed as uuid, real ids are tx-001, c1, u1</b>                  | Annexe E format: uuid vs live payloads. Annexe F.1 makes it worse:<br>"recipientId":<br>"c1-3a8f-4d2b-95e1-77a1"<br>is not a valid UUID either<br><b>[verified]</b> |
| C-03 | <b>Documented demo data does not exist</b>                            | Annexe F.6 lists 12/08/2026 "Loyer juillet" etc.; the environment serves 2025-07-01...2025-07-22 with different labels<br><b>[verified]</b>                         |
| C-04 | <b>Documented totals are unreachable</b>                              | Annexe F.6 says table \$44,800 / KPI \$48,291. Live data sums to <b>-\$389.66</b> (all) or <b>\$1,883.14</b> (completed)<br><b>[verified]</b>                       |
| C-05 | <b>Enum constraints not enforced</b>                                  | Annexe E constrains status to 3 values; ?status=not-a-real-status returns 200 [] instead of 400 <b>[verified]</b>                                                   |
| C-06 | <b>/health, /ready, /metrics documented as expected, none exposed</b> | Annexe D vs 404 on all three <b>[verified]</b>                                                                                                                      |

## 6.2 Internal contradictions within the brief

| #    | Contradiction                                                                                                                                                                                                                                                                                                                                                                                                                  |
|------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| C-07 | <b>R03 says "\$9,999.99, validation côté formulaire"</b> while Annexe E sets no maximum on amount at all. The rule is documented as client-side <i>by design</i> — on a payments API that is not a ceiling, it is a suggestion. Annexe H TC-03 confirms it: 100,000,000 cents accepted, 201.                                                                                                                                   |
| C-08 | <b>Idempotency-Key appears in both Annexe F sample requests but in no contract, no business rule and no NFR.</b> A guarantee that exists only in an example is not a guarantee.                                                                                                                                                                                                                                                |
| C-09 | <b>R08 says the PIN is SHA-256 hashed client-side.</b> Client-side hashing of a 6-digit PIN is security theatre: the hash <i>becomes</i> the password (replayable), and the full 10 <sup>6</sup> pre-image space is exhaustible in under a second. Annexe H TC-05 asserts the regex and passes — the test is green and the control is still ineffective. Unsalted SHA-256 also contradicts Annexe D's "encryption in transit". |



| #           | Contradiction                                                                                                                                                                                                                                                                                                                             |
|-------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>C-10</b> | <b>Annexe B.2 says “15 transactions de démo, pagination par 5 lignes”</b> — 15 records confirmed <b>[verified]</b> , but Annexe F.6 says “9 autres lignes” after listing 6, and its figures match neither.                                                                                                                                |
| <b>C-11</b> | <b>Annexe D mandates “MFA obligatoire pour Admin”</b> while Annexe A supplies a plain e-mail/password Admin login with no second factor. The NFR is annotated “non vérifiée dans le code” — so the policy and the product disagree, in writing.                                                                                           |
| <b>C-12</b> | <b>Timezone ambiguity.</b> Annexe A: UTC technical / Europe-Paris display. Annexe H TC-02 fails with expected 2026-08-15 to equal 2026-08-14 — a classic off-by-one-day at a timezone boundary. Nothing states whether scheduledDate is a wall-clock date in Paris or a UTC instant. On a scheduled payment this is a real one-day error. |
| <b>C-13</b> | <b>Annexe D sets a rate limit of 10 req/min/user on /transfers, but Annexe E documents no 429</b> and Annexe F shows no Retry-After. A client cannot handle a limit it cannot recognise.                                                                                                                                                  |
| <b>C-14</b> | <b>Role capabilities are qualitative and untestable as written.</b> “Vue équipe” (Manager) and “Vue individuelle” (Membre) do not define a data-scoping rule. I cannot write a pass/fail assertion against “team view”.                                                                                                                   |

### 6.3 Silent gaps, no contradiction, just absence

- No error schema anywhere. Annexe E documents 400/401/403 as bare descriptions with no body. A client cannot distinguish “insufficient funds” from “invalid PIN”, so the UI cannot show a useful message.
- No 409: 422 or 429 documented, despite the brief naming all three.
- No pagination contract: though the UI paginates by 5.
- **No DELETE /transactions/{id} contract:** though R09 describes deletion — and deleting a financial record at all contradicts Annexe D’s “7 ans, immuable”. *Deletion and immutable audit retention cannot both be true.*
- No currency handling beyond a USD default: in a product whose own domain statement lists “gestion des devises” as mandatory.

## 7. Risk matrix

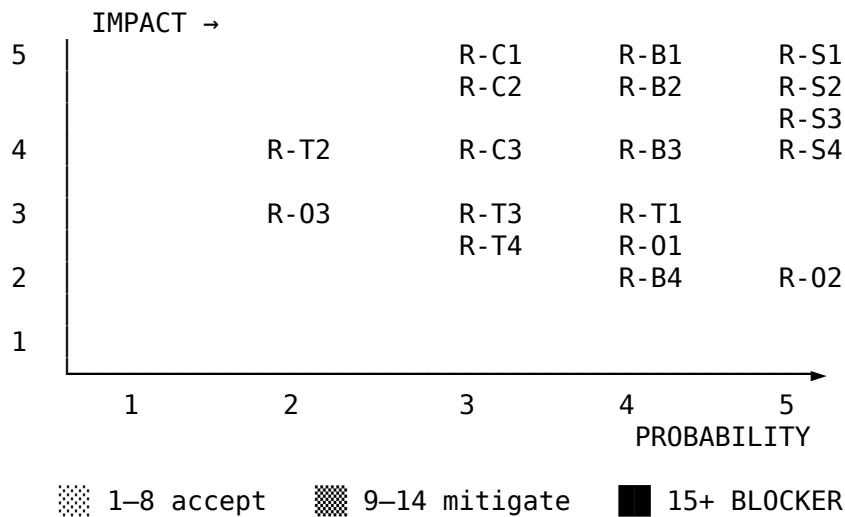
Probability × Impact, scored 1-5, across the four required dimensions. **Exposure = P × I**. Anything ≥ 15 is a launch blocker in my judgement.

| ID          | Dimension             | Risk                                                         | P | I | Exp.      | Evidence                                               | Mitigation                                                               |
|-------------|-----------------------|--------------------------------------------------------------|---|---|-----------|--------------------------------------------------------|--------------------------------------------------------------------------|
| <b>R-S1</b> | Security              | Unauthenticated read of /users, /contacts, /transactions     | 5 | 5 | <b>25</b> | <b>[verified]</b> — 200 + full payload, no credentials | TS-01, TS-01b, TS-02. Gateway auth middleware. <b>No-Go until closed</b> |
| <b>R-S2</b> | Security / Compliance | No tenant scoping — ?userId= ignored, global ledger returned | 5 | 5 | <b>25</b> | <b>[verified]</b> ; Annexe H TC-12                     | TS-02. Server-side scoping from the token                                |
| <b>R-B1</b> | Business              | No server-side transfer ceiling → unbounded debit            | 4 | 5 | <b>20</b> | Annexe H TC-03: \$1M accepted, 201                     | TS-04 boundary set. Move R03 server-side                                 |
| <b>R-B2</b> | Business              | Duplicate debit — idempotency unenforced                     | 4 | 5 | <b>20</b> | Annexe G-B: two keyless POSTs, both settled            | TS-03. Mandatory key + dedup window                                      |
| <b>R-S3</b> | Security              | Role boundary breach on /admin/users                         | 4 | 5 | <b>20</b> | Annexe H TC-11: expected 403, got 200, 8 records       | TS-01, TS-10b                                                            |
| <b>R-B3</b> | Business              | Balance KPI not derivable from the ledger                    | 4 | 4 | <b>16</b> | Annexe F.6 \$3,491 gap; <b>[verified]</b>              | TS-08b — <b>blocked on Q2</b>                                            |
| <b>R-C1</b> | Compliance            | Deletion vs 7-year immutable retention                       | 3 | 5 | <b>15</b> | unreproducible R09 vs Annexe D                         | Escalate to Legal. Soft-delete + audit log                               |
| <b>R-C2</b> | Compliance            | MFA mandated for Admin, absent in product                    | 3 | 5 | <b>15</b> | C-11                                                   | Confirm scope before public exposure                                     |

| ID          | Dimension   | Risk                                                                                     | P | I | Exp.      | Evidence                        | Mitigation                               |
|-------------|-------------|------------------------------------------------------------------------------------------|---|---|-----------|---------------------------------|------------------------------------------|
| <b>R-T1</b> | Technical   | Contract/implementation divergence on money typing                                       |   | 3 | <b>15</b> | C-01<br><b>[verified]</b>       | TS-06b. Regenerate contract from reality |
| <b>R-O1</b> | Operational | No /health, /ready, /metrics → 15-min RTO                                                | 5 | 3 | <b>15</b> | <b>[verified]</b><br>404 × 3    | TS-10c. Expose probes                    |
| <b>R-S4</b> | Security    | unmeasurable Client-side PIN hashing is ineffective (re-playable, 10 <sup>6</sup> space) | 4 | 4 | <b>16</b> | C-09                            | Server-side KDF + attempt lockout        |
| <b>R-T2</b> | Technical   | Webhook signature failures (89)                                                          | 3 | 4 | 12        | Annexe I                        | <b>Blocked on Q5</b>                     |
| <b>R-O2</b> | Operational | unexplained Demo data ≠ documented data                                                  | 5 | 2 | 10        | C-03, C-04<br><b>[verified]</b> | Data-independent invariant tests         |
| <b>R-T3</b> | Technical   | No test-data isolation — shared mutable environment                                      | 4 | 3 | 12        | H-08                            | Serialized writes; per-run unique keys   |
| <b>R-C3</b> | Compliance  | Timezone ambiguity on scheduled payments                                                 | 3 | 4 | 12        | C-12, Annexe H TC-02            | Specify, then boundary-test              |
| <b>R-T4</b> | Technical   | No error schema → clients cannot handle failure                                          | 4 | 3 | 12        | §6.3                            | Define RFC 7807 problem details          |
| <b>R-O3</b> | Operational | Rate limit undocumented as 429                                                           | 3 | 3 | 9         | C-13                            | Document, then test                      |

| ID          | Dimension | Risk                                          | P | I | Exp. | Evidence          | Mitigation        |
|-------------|-----------|-----------------------------------------------|---|---|------|-------------------|-------------------|
| <b>R-B4</b> | Business  | Manager owns no contacts — journey untestable | 4 | 2 | 8    | <b>[verified]</b> | Fix the seed data |

### Exposure map



**Six risks score  $\geq 20$ , and five of those six are security or financial integrity.** None is a rendering defect. This is what shapes the whole strategy: effort goes to the API boundary, where those risks live, not to the UI, where they do not.

## 8. What I would need to raise confidence

Ranked by value per hour, since the brief asks for judgement rather than a wish list:

1. **Answers to Q1-Q5**, free, and unblocks H-02, H-04, H-05 plus two tests.
2. **A dedicated, resettable test tenant**, removes R-T3 and R-02 and makes parallel execution safe, cutting suite runtime severalfold.
3. **A webhook signing secret + replayable event**, opens J5, currently at zero coverage on a trust boundary.
4. **Read access to Prometheus and Kafka**, turns Annexe I from a static extract into a live assertion, and lets me verify NFRs instead of citing them.
5. **The error-response schema**, one document, and it makes every negative test assert on semantics rather than on a bare status code.

*Prepared for Phase 2 (Test Strategy). All items marked **[verified]** were reproduced against the demonstration environment on 15 August 2026 and are evidenced in docs/05-results-analysis.md.*